

Integrated case & exam workshop — MediCloud

Session 13 – Bringing it all together

Exercise 13 · Capstone workshop · Estimated time: 90–120 min

Write your answers in the answer document `SKY2100_Exercise13_Answers.docx`. Today you apply the whole course to one scenario. There is **no single correct design** – several are valid. What is assessed is whether you cover the lifecycle, recognise trade-offs, and justify your choices against the context.

Note: Bring your answer documents from S1–S12 — above all your knowledge-check answers and your CSF 2.0 mapping (S12). The case draws on all of them.

The brief — MediCloud

MediCloud is a small health-tech start-up. Clinics use its web app to upload and share patient records (much like your Nextcloud). It is moving from one office server to the cloud. Constraints: sensitive health data under GDPR; small team; limited budget; clinics need it available during working hours.

AHA. This case has no single correct design, and that is the point of it. Two very different answers can both be right: a lean self-managed VM with tested backups, or a managed PaaS setup with a cloud SIEM and multi-region failover. What is assessed is not which one you pick but whether you cover the whole lifecycle, name the alternative you rejected, and justify your choice against MediCloud’s health data, small team and limited budget. “No single answer” is not “anything goes”, though. A handful of things must be true in any valid design, such as encryption in transit and at rest, least privilege with MFA, and backups that are restore-tested. The trade-offs live around those fixed points, and a design that skips one is wrong however cleverly it is argued.

1 Design across the CSF 2.0 functions

▷ Sketch a security design for MediCloud.

For each function — Identify, Protect, Detect, Respond, Recover, Govern — state in the design table of the answer document your decision, the main alternative you considered, and a one-line justification.

▷ **Govern in depth.** The Govern row is where most designs are thin. Do three concrete things an auditor would expect:

- **Risk register:** write one row for MediCloud — asset, threat, risk level (impact × likelihood), owner, review date (CSA Domain 3, p. 65–66).
- **Assurance:** name which provider report MediCloud should require before trusting the cloud with patient data — a **SOC 2 / ISAE 3402** attestation, **ISO/IEC 27001**, **BSI C5**, or a **CSA STAR** entry — and say whether it is an audit or an attestation.
- **Exit strategy:** how would MediCloud get its data out if it had to leave the provider? State the reversibility / anti-lock-in plan (a resilience-against-provider-failure control, and a DORA expectation for regulated sectors).

2 Defend two trade-offs

▷ Pick two functions where you had a real choice. For each, give two reasonable options, their trade-offs, your decision, and why – tied to MediCloud’s health data and small budget.

3 The non-negotiables

▷ “No single answer” does not mean “anything goes”. List the things that must be true in any valid MediCloud design, and say which session each comes from.

Note: Strong lists include: encryption in transit and at rest (S6); least privilege with no shared admin accounts, plus 2FA (S7); backups that exist and are restore-tested (S11); logging of access to patient data (S9, also a GDPR/NIS2 requirement); and a documented **exit / data-portability** plan (S5/S11). The trade-offs live around these fixed points — a design that skips one is wrong, however cleverly justified.

4 Brief the founders (plain language)

▷ The founders are clinicians, not engineers. In 4–5 sentences, explain your design in terms of risk and outcomes – no jargon. Be honest about one thing you chose not to do and why.

5 Mock exam — scenario practice

Answer briefly, using the method: assumptions → options → trade-offs → decision → justification.

1. MediCloud’s budget allows either a managed SIEM or multi-region failover, not both. Which would you fund first, and why?

Hint: Either is defensible — justify by the bigger gap you have right now.

2. A clinician reports the app was briefly unreachable this morning. Walk through how you would tell whether this was an incident – which logs, which steps (S9–S10)?

Hint: Validate first (S9–S10): read the access log and fail2ban before calling it an attack.

3. Justify, in one sentence each, whether MediCloud needs: (a) a WAF, (b) multi-provider resilience, (c) immutable backups.

Hint: The app takes untrusted web input — cheap, high-value protection fits.

4. Where does the line of shared responsibility sit if MediCloud chooses PaaS instead of a self-managed VM?

Hint: PaaS moves OS patching to the provider; you still own data, identity, config.

5. Name one way MediCloud could safely use AI, and one governance rule it should set for that use.

Hint: Safe use: anomaly detection or alert summarisation for a small team — and declare it.

6 Self-check against the revision map

▷ For each CSF function, write in the revision map of the answer document the single most important idea you must be able to explain in the exam. If any row is blank, that is your revision priority.

Progress check: Discuss your designs in the group, then talk the teacher through them verbally; nothing is handed in, signed or graded. This workshop is preparation for the exam.

Solutions

Work through the lab first, then check here. Model answers are indicative — equivalent reasoning is fine.

How to use this key. This case has no single correct answer. Do not mark for a specific architecture – mark for coverage of the lifecycle, recognition of trade-offs, and justification against the context (health data, small team, budget). Below are two valid reference designs, the non-negotiables, a grading rubric, and model directions for the mock questions.

Two valid reference designs

- **Design 1 – lean / self-managed.** Hardened VM (S7) running the app with TLS (S6) and a WAF (S8); self-hosted logs + fail2ban + WAF audit log, read by the team (S9); manual IR with a simple playbook (S10); single-region with tested, immutable backups and a defined RPO/RTO (S11); governed to NIST CSF 2.0 + GDPR, with a written AI-use policy (S12). Fits a skilled, budget-tight team that accepts more operational load.
- **Design 2 – managed.** PaaS web app (provider patches the OS); managed WAF; managed SIEM (Sentinel) + SOAR for detection and response; multi-region failover for higher availability; provider-managed automated backups; same CSF 2.0 + GDPR governance. Fits a team that prefers to pay to offload risk and operational burden.

Both are defensible. A weak answer is gold-plated (“multi-provider + full SOC + every product”) with no reference to budget, team size, or the risk each control addresses.

The non-negotiables (must appear in any valid design)

- Health data **encrypted in transit and at rest** (S6) – not optional under GDPR.
- **Least privilege**, no shared admin accounts, MFA on admin access (S7).
- Backups that **exist and are restore-tested**; access to patient data **logged** (S9, S11).
- A response plan, however lightweight, and a clear **owner/accountability** (S10, S12).

A design that omits a non-negotiable is wrong regardless of how well the rest is justified.

Govern in depth (model answers)

- **Risk-register row:** e.g. patient records / unauthorised disclosure / Critical (high×moderate) / owner: MediCloud DPO / review: annual. Accept any defensible row with a level derived from impact × likelihood (CSA Domain 3).
- **Assurance report:** for health data a strong answer requires the provider’s **ISO/IEC 27001** certificate and/or a **SOC 2 / ISAE 3402** attestation (and notes **BSI C5** for a German market, or the **CSA STAR** entry). Must classify it: SOC 2 = attestation; ISO 27001 = certification/audit. The student should name one thing to check (scope, exceptions, the report period, sub-service organisations).
- **Exit strategy:** data export in an open format, documented restore-elsewhere procedure, avoiding proprietary lock-in; for a regulated start-up this is also a **DORA**-style expectation. A design with no exit plan is a real audit finding.

Grading rubric (what separates strong from weak)

- **Strong:** covers all six CSF functions; offers options with trade-offs; decisions justified against MediCloud’s specific context; honest about what is not done and why; non-negotiables respected; communicates in plain risk language.
- **Adequate:** covers most functions; some justification; at least one explicit trade-off.

- **Weak:** lists tools with no reasoning; ignores budget/team; gold-plated or missing a non-negotiable; no trade-offs; one “right answer” asserted without context.

Mock exam — model directions

1. **SIEM vs multi-region (fund first).** Either can be justified. Common strong answer: fund the managed SIEM first – detection of a breach of patient data (confidentiality) is the higher risk for health records, and single-region + tested backups already cover most availability needs; multi-region addresses a rarer regional-outage risk. The reverse is acceptable if justified by an availability-critical context. Mark the reasoning, not the pick.
2. **Incident or not?** Validate the alert (S9–S10): check the web/access log and `journalctl` for an outage/restart, `auth.log`/fail2ban for suspicious logins, the WAF log for blocked attacks; correlate timestamps into a short timeline; decide event vs incident vs breach; if an incident, follow the lifecycle (contain, analyse, recover, learn). A brief outage with a benign cause (e.g. a restart) is an event, not necessarily an incident.
3. (a) **WAF – yes:** the app handles untrusted input over the web; cheap, high-value protection against injection/XSS against patient data. (b) **Multi-provider – no (for a start-up):** complexity and cost outweigh the benefit; single- or multi-region is proportionate. (c) **Immutable backups – yes:** ransomware against health data is a real, high-impact threat; immutability is low-cost insurance.
4. **Shared responsibility with PaaS:** the provider takes on OS patching, runtime and more of the platform; MediCloud still owns its data, access control, app configuration, encryption choices and monitoring of its own activity. Choosing PaaS legitimately shifts operational burden to the provider – a sound move for a small team.
5. **AI use + governance rule.** Safe use: anomaly detection or alert summarisation to help a small team triage (S9, S12). Governance rule examples: keep a human accountable for decisions; do not feed patient data into tools that may retain it; disclose where AI is used. Any sensible pairing is fine.

References

Synthesises the whole course. Frameworks: **NIST CSF 2.0** (Govern, Identify, Protect, Detect, Respond, Recover; verified, Feb 2024); CSA Security Guidance v5 – shared responsibility & governance (Domains 1–2), IAM & hardening (Domain 5), application security (Domain 10), security monitoring (Domain 6), incident response & resilience (Domain 11). Comer, The Cloud Computing Book – foundations, storage/RAID (Ch. 8), DevOps (Ch. 15), security & AI (Ch. 17). Maps to course sessions S1–S12.